

Remediation Plan

Prioritized 180-day corrective-action roadmap with owners, mappings and closure evidence.

Document ID	PCI-V2-RP-006
Prepared by	Richmond Kwadwo Sarpong
Case study	Akwaaba Retail & Online Ltd. (fictional)
Date / version	20 August 2026 / Version 2.0

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

Remediation Strategy

The roadmap first contains immediate data and access risks, then strengthens repeatable evidence, independent testing and continuous governance. Priority reflects security exposure and sequencing dependencies.

Target	Remediation action	Mapped gaps / risks	Owner	Closure evidence / success metric	Priority
0-7 days	Contain PAN logging and preserve authorized evidence; securely remove prohibited data	G-04 / R-01	CISO + App Owner	Log samples show no PAN; deletion approval and validation retained	Critical
0-14 days	Enforce MFA for all applicable CDE access and remove undocumented bypasses	G-12 / R-02	IAM Lead	100% applicable accounts protected; authentication tests pass	High
0-30 days	Patch critical vulnerabilities and disable obsolete TLS configurations	G-06, G-08 / R-04, R-09	Infrastructure Lead	Passing rescans; approved exceptions equal zero	High
0-30 days	Inventory and authorize payment-page scripts; deploy integrity and tamper monitoring	G-10, G-18 / R-03	Engineering Lead	All scripts justified; alerts tested; change workflow approved	High
0-30 days	Restrict broad CDE firewall access and update network/data-flow diagrams	G-01, G-02 / R-05	Network Lead	Approved rules; diagrams reconciled; connectivity tests pass	High
31-60 days	Deploy complete malware protection and centralize critical log sources with daily review	G-07, G-14, G-15 / R-06	SOC Lead	Coverage and log-source inventory reach 100%; daily tickets retained	High
31-60 days	Complete access recertification for users, service accounts and vendors	G-11 / R-02	System Owners	All access approved or removed; exceptions have owners and expiry	Medium
31-60 days	Obtain TPSP AOCs and complete the responsibility matrix	G-20 / R-07	Compliance Lead	All critical services mapped to current assurance and responsibilities	Medium
31-90 days	Run passing ASV scans and complete expanded penetration/segmentation testing	G-16, G-17 / R-05	Security Manager	Passing reports and verified closure of findings	High
31-90 days	Automate retention and deletion; verify POS inspections and physical records	G-05, G-13 / R-08	Data Owner + Retail Ops	Deletion and inspection evidence complete for the review period	Medium
61-90 days	Complete targeted risk analyses, developer training and a payment-incident tabletop	G-09, G-19, G-20 / R-10	Compliance Lead	Approved analyses; training completion; lessons tracked to closure	High
91-180 days	Establish continuous control monitoring and quarterly internal PCI readiness reporting	All	CISO + Compliance	Dashboard reports evidence freshness, exceptions, risk and remediation status	Medium

Implementation Checkpoints

Gate	Management decision check	Evidence required
Day 7	Has prohibited PAN logging stopped and has affected data been handled through an approved process?	Validated log samples, deletion approval and incident decision record
Day 30	Are urgent identity, patching, transport, script and firewall gaps closed?	Passing technical tests, approved rule changes and MFA coverage report
Day 60	Are control owners producing repeatable access, logging, malware and third-party evidence?	Evidence tracker, review tickets, coverage reports and current TPSP assurance
Day 90	Have independent scans, penetration/segmentation tests and the IR exercise confirmed effectiveness?	Passing ASV result, retest reports and approved exercise lessons
Day 180	Is PCI readiness operating as a continuous governance process?	Quarterly dashboard, exception register, risk acceptance and management review

Closure Acceptance Criteria

- Control design directly addresses the mapped PCI DSS objective and documented risk.
- Control operates across the full scoped population, including third-party and service accounts where applicable.
- Evidence is dated, attributable, complete, securely stored and reproducible by an independent reviewer.
- Technical retesting confirms the weakness is removed and no unacceptable side effects were introduced.
- Policies, inventories, diagrams, training and operational procedures are updated to sustain the change.

Acronyms and Definitions

Document-specific reference glossary for **Remediation Plan**. Definitions are written in plain language for recruiters, reviewers and non-specialist readers.

Acronym	Full meaning and explanation
AOC	Attestation of Compliance A formal declaration that applicable PCI DSS requirements have been assessed.
ASV	Approved Scanning Vendor A company approved by the PCI SSC to perform external vulnerability scanning services.
CDE	Cardholder Data Environment The people, processes and technologies that store, process or transmit cardholder data, or can affect its security.
CHD	Cardholder Data At minimum, the primary account number; it may also include the cardholder name, expiration date or service code.
MFA	Multi-Factor Authentication Authentication using at least two different factor types before access is granted.
PCI DSS	Payment Card Industry Data Security Standard The global security standard for protecting payment account data.
POA&M;	Plan of Action and Milestones A tracked plan describing corrective actions, ownership, deadlines and closure evidence.
QSA	Qualified Security Assessor A PCI SSC-qualified organization or individual that performs PCI DSS assessments.
RACI	Responsible, Accountable, Consulted and Informed A matrix used to clarify roles and decision ownership.
ROC	Report on Compliance A detailed report documenting the results of a PCI DSS assessment.
SAQ	Self-Assessment Questionnaire A validation tool for eligible entities to document PCI DSS self-assessment results.
SIEM	Security Information and Event Management Technology that centralizes and analyzes security logs and alerts.
SLA	Service-Level Agreement A documented commitment defining service performance, responsibilities and response expectations.
TPSP	Third-Party Service Provider An external provider whose services store, process, transmit or can affect the security of account data.

Portfolio note: This glossary supports a fictional PCI DSS v4.0.1 readiness case study and does not represent a formal compliance determination.